

Clase 284 — Gestión de riesgo de terceros y proveedores

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: (ISC)² CISSP Official Study Guide y NIST SP 800-161

 Duración estimada: **90 min** · Nivel: **Intermedio**

Objetivo

Aprender a gestionar el riesgo que introducen proveedores, subcontratistas y la cadena de suministro de software (TPRM, Third-Party Risk Management). Incidentes como SolarWinds, Log4j o MOVEit demostraron que la mayor amenaza a menudo entra por un tercero de confianza. Al terminar sabrás evaluar proveedores, exigir cláusulas contractuales de seguridad, gestionar el ciclo de vida del proveedor y responder a un compromiso en la cadena de suministro.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Explicar** por qué el riesgo de terceros amplía la superficie de ataque.
2. **Ejecutar** una evaluación de riesgo de un proveedor (due diligence).
3. **Redactar** cláusulas de seguridad contractuales (SLA, derecho a auditar, notificación de brechas).
4. **Clasificar** proveedores por criticidad y nivel de acceso a datos.
5. **Gestionar** el ciclo de vida del proveedor, incluida la salida (offboarding).

Temas

#	Tema	Por qué importa
1	Superficie de ataque de terceros	Confías tanto como tu eslabón más débil
2	Ciclo de vida del proveedor	De la selección al offboarding
3	Due diligence y cuestionarios (SIG, CAIQ)	Evaluar antes de contratar
4	Cláusulas contractuales y SLA	La seguridad debe estar en el contrato
5	Riesgo de cuarta parte (4th party)	Los proveedores de tus proveedores
6	Cadena de suministro de software (SBOM)	Log4j, SolarWinds, dependencias
7	Monitorización continua	El riesgo no es estático

Explicación en profundidad

El tercero se evalúa por servicio, datos, accesos, concentración y sustituibilidad, no por cuestionario genérico. La diligencia previa establece condiciones; contrato asigna responsabilidades; monitorización observa cambios; salida recupera datos, accesos y continuidad.



Caso razonado

Un SaaS posee ISO 27001, pero su subprocesador crítico no está incluido en alcance. Se revisa certificado, SoA, arquitectura y contrato antes de aceptar evidencia.

Glosario operativo

Término	Definición
Cuarta parte	Proveedor utilizado por el tercero.
Concentración	Dependencia común capaz de afectar múltiples servicios.
Exit plan	Ruta probada para terminar relación y recuperar capacidad.

Criterio de dominio

Existe dominio cuando el alumno adapta diligencia al servicio, valida alcance de evidencia y diseña monitoreo, incidente y salida.

Definiciones y características

- **TPRM:** gestión del riesgo de terceros a lo largo de todo su ciclo de vida. *Clave:* proceso continuo, no un chequeo único.
- **Due diligence:** investigación previa del proveedor (financiera, de seguridad, legal). *Clave:* antes de firmar.
- **Cuestionario de seguridad:** SIG (Shared Assessments) o CAIQ (Cloud Security Alliance) para evaluar controles. *Clave:* estandariza la evaluación.
- **SLA (Service Level Agreement):** compromiso de nivel de servicio medible. *Clave:* incluye disponibilidad, soporte y seguridad.
- **Derecho a auditar (right to audit):** cláusula que permite verificar los controles del proveedor. *Clave:* convierte promesas en verificables.
- **Cuarta parte:** proveedor del que depende tu proveedor. *Clave:* heredas su riesgo sin controlarlo directamente.
- **SBOM (Software Bill of Materials):** inventario de componentes de un software. *Clave:* permite saber si te afecta un CVE de una dependencia.

Herramientas y preparación

- Un cuestionario de referencia: CAIQ de Cloud Security Alliance (descarga gratuita) o SIG Lite.
- Hoja de cálculo para el inventario y la matriz de criticidad de proveedores.
- Para SBOM: herramientas como `syft` (`syft <imagen>` genera un SBOM) y `grype` para cruzarlo con CVEs.
- Referencia: NIST SP 800-161 (Cybersecurity Supply Chain Risk Management) y controles SOC 2 Type II.

Laboratorio guiado (ejercicio aplicado)

Parte A — Inventario y evaluación para "Ferretería del Sur S.A.":

1. **Inventario de proveedores:** lista 6 (pasarela de pago, proveedor cloud, CRM SaaS, agencia de marketing, mensajería, ERP). Para cada uno anota qué datos accede y qué nivel de acceso tiene.
2. **Matriz de criticidad:** clasifica cada proveedor en crítico/medio/bajo según acceso a datos sensibles e impacto si falla. La pasarela y el cloud serán críticos.
3. **Due diligence:** para el proveedor más crítico, prepara un mini-cuestionario de 10 preguntas basado en CAIQ (¿tiene ISO 27001/SOC 2? ¿cifra datos? ¿notifica brechas en cuánto tiempo? ¿dónde aloja los datos?).
4. **Cláusulas contractuales:** redacta 5 cláusulas de seguridad para el contrato: notificación de brechas en 48 h, derecho a auditar, ubicación de datos en la UE, subencargados con aprobación previa, borrado seguro al finalizar.

Parte B — Riesgo de cadena de suministro de software:

5. Genera un SBOM de una imagen de contenedor en tu laboratorio:

```
syft nginx:latest -o table > sbom.txt
grype nginx:latest      # cruza los componentes con CVEs conocidos
```

6. Identifica en la salida un componente con CVE y anota qué harías (actualizar, mitigar, aceptar).

Parte C — Offboarding:

7. Redacta la checklist de salida de un proveedor: revocar accesos y API keys, confirmar borrado de datos, recuperar activos, cerrar integraciones.

Ejercicios

1. Explica el ataque a SolarWinds como ejemplo de riesgo de cadena de suministro.
2. ¿Qué es un proveedor de cuarta parte y por qué te preocupa?
3. Redacta 3 preguntas clave de due diligence para un SaaS que trata datos personales.
4. Diseña una matriz de criticidad de proveedores con 2 ejes.
5. ¿Por qué un SBOM es útil cuando aparece un CVE crítico como Log4Shell?
6. Enumera los pasos de offboarding seguro de un proveedor con acceso API.

Reto verificable

Entrega un **programa TPRM mínimo** con: inventario de al menos 6 proveedores clasificados por criticidad, cuestionario de due diligence del proveedor crítico, 5 cláusulas contractuales de seguridad, evidencia de un SBOM con al menos un CVE identificado y una checklist de offboarding.

Criterio de aceptación: la clasificación de criticidad se justifica por acceso a datos e impacto, las cláusulas incluyen notificación de brechas y derecho a auditar, y el SBOM muestra un componente vulnerable con acción propuesta.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Evaluar al proveedor solo al contratar	El riesgo evoluciona; monitoriza de forma continua
Contrato sin cláusulas de seguridad	No puedes exigir nada tras una brecha; inclúyelas antes de firmar
Ignorar a los subencargados (4ª parte)	Heredas su riesgo; exige transparencia y aprobación
No revocar accesos al terminar	Cuentas huérfanas de terceros; checklist de offboarding
Confiar en el logo "ISO 27001" sin ver el alcance	El certificado puede cubrir otra cosa; pide el SoA/alcance

Preguntas frecuentes

 **¿Basta con que el proveedor tenga SOC 2 o ISO 27001?** Es buena señal, pero debes verificar el alcance (qué cubre) y que sea vigente. Un certificado no exime de tus propias obligaciones legales sobre los datos.

 **¿Qué diferencia hay entre SIG y CAIQ?** Ambos son cuestionarios de evaluación de proveedores; CAIQ (CSA) está orientado a la nube, SIG (Shared Assessments) es más general. Elige según el tipo de proveedor.

 **¿Por qué importa el SBOM?** Cuando aparece una vulnerabilidad en una librería (Log4Shell), el SBOM te dice en minutos qué productos tuyos y de terceros están afectados, en lugar de días de investigación manual.

 **¿Soy responsable de una brecha en mi proveedor?** Ante GDPR sigues siendo responsable de los datos que le confías. Por eso exiges cláusulas, auditoría y notificación rápida.

Referencias

- NIST SP 800-161 Rev.1 — Supply Chain Risk Management. <https://csrc.nist.gov/pubs/sp/800/161/r1/final>
- Cloud Security Alliance — CAIQ. <https://cloudsecurityalliance.org/research/caiq>
- Shared Assessments — SIG Questionnaire. <https://sharedassessments.org/sig/>
- Syft & Gype (SBOM y escaneo). <https://github.com/anchore/syft>
- (ISC)² CISSP Official Study Guide, dominio 1.

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 283 — Continuidad de negocio y plan de recuperación ante desastres](#)

Siguiente clase

Clase 285 — Auditoría de seguridad